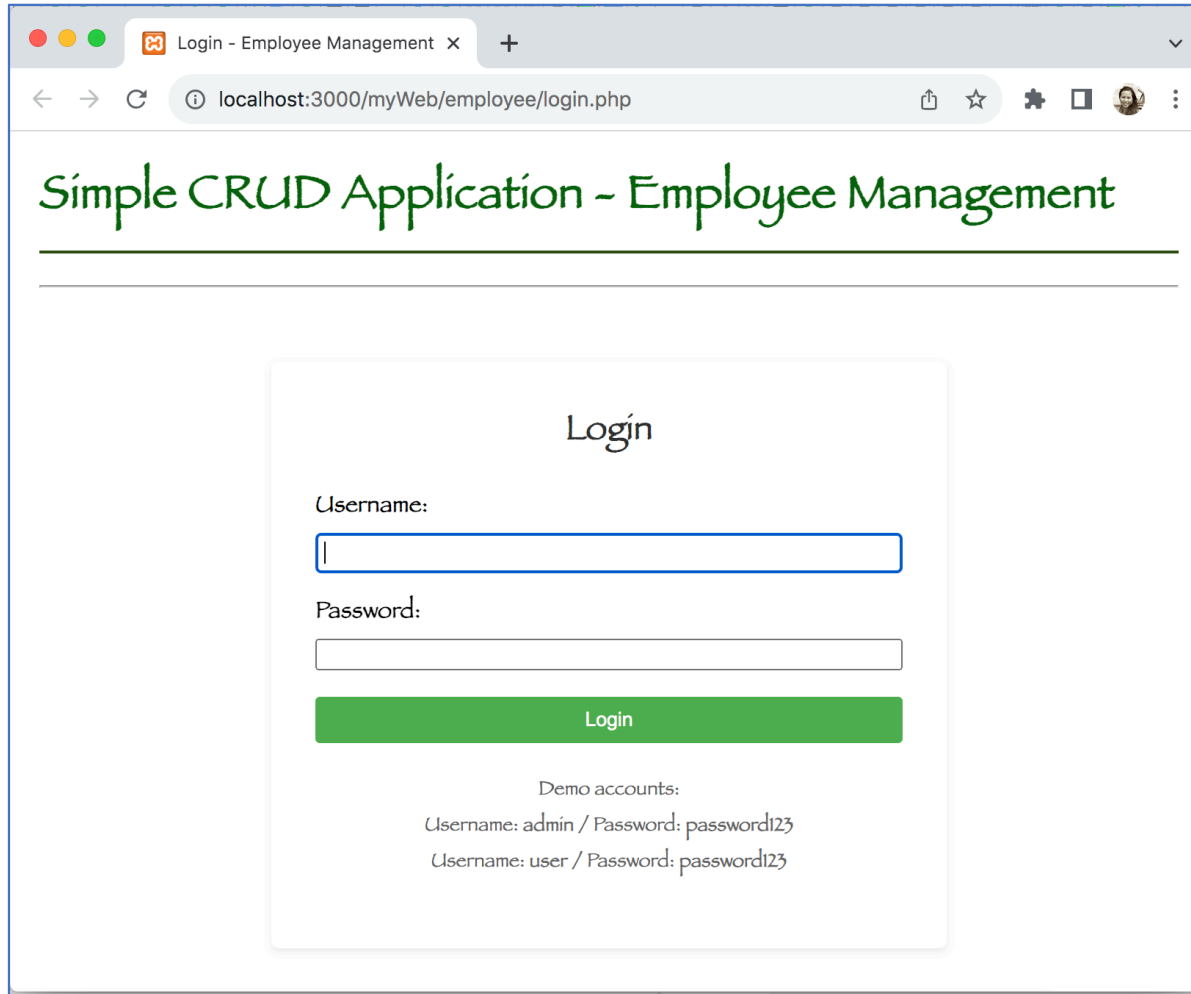


◆ Login, Logout and Permission Checking



Session handling
DIY

Login, Logout and Permission Checking



The screenshot shows a web browser window with the following details:

- Tab:** Login - Employee Management
- Address Bar:** localhost:3000/myWeb/employee/login.php
- Page Title:** Simple CRUD Application - Employee Management
- Login Form:**
 - Username:** A text input field.
 - Password:** A password input field.
 - Login Button:** A green button labeled "Login".
- Demo accounts:**
 - Username: admin / Password: password123
 - Username: user / Password: password123

◆ Adding users

```
CREATE TABLE users (  
    id INT(11) UNSIGNED AUTO_INCREMENT PRIMARY KEY,  
    username VARCHAR(50) NOT NULL UNIQUE,  
    password VARCHAR(255) NOT NULL,  
    role ENUM('admin', 'user') NOT NULL DEFAULT 'user',  
    created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP);  
  
INSERT INTO users (username, password, role)  
VALUES('admin',  
    '$2y$10$bagrmUSBh6PS/18.q2IkQuaBo7dCtrGeKxtEEnT8uDDWScCoBtoJ0',  
    'admin'),  
('user',  
    '$2y$10$bagrmUSBh6PS/18.q2IkQuaBo7dCtrGeKxtEEnT8uDDWScCoBtoJ0', 'user');
```

◆ Create data/auth.php

```
<?php
// Start session if not already started
if (session_status() === PHP_SESSION_NONE) { session_start(); }
// Check if user is logged in
function isLoggedIn() { return isset($_SESSION['user_id']) && isset($_SESSION['username']); }
// Check if user is admin
function isAdmin() { return isset($_SESSION['role']) && $_SESSION['role'] === 'admin'; }
// Require login - redirect to login page if not logged in
function requireLogin() {
    if (!isLoggedIn()) { header("Location: login.php"); exit(); }
}
// Require admin - redirect if not admin
function requireAdmin() { requireLogin();
    if (!isAdmin()) {header("Location: index.php?error=" . urlencode("Access denied.
Admin privileges required.")); exit(); }
}
// Get current user info
function getCurrentUser() {
    if (isLoggedIn()) { return [ 'id' => $_SESSION['user_id'],
        'username' => $_SESSION['username'], 'role' => $_SESSION['role'] ]; }
    return null;
}
?>
```

◆ Create login.php

```
<?php
session_start();
include 'data/connect-select-db.php';
// If already logged in, redirect to home
if (isset($_SESSION['user_id'])) { header("Location: index.php"); exit(); }
$error = '';
if ($_SERVER['REQUEST_METHOD'] == 'POST') {
    $username = mysqli_real_escape_string($conn, $_POST['username']);
    $password = $_POST['password'];
    $sql = "SELECT * FROM users WHERE username = '$username'";
    $result = mysqli_query($conn, $sql);
    if (mysqli_num_rows($result) == 1) {
        $user = mysqli_fetch_assoc($result);
        if (password_verify($password, $user['password'])) {
            // Set session variables
            $_SESSION['user_id'] = $user['id'];
            $_SESSION['username'] = $user['username'];
            $_SESSION['role'] = $user['role'];
            header("Location: index.php"); exit();
        } else { $error = "Invalid username or password"; }
    } else { $error = "Invalid username or password"; }
}
mysqli_close($conn);
?>
```

Create login.php

```
<!DOCTYPE html>
<html lang="en">
  <head> <meta charset="UTF-8"> <meta name="viewport" content="width=device-width, initial-
scale=1.0"> <title>Login - Employee Management</title>
    <link rel="stylesheet" href="css/style.css">
  </head>
  <body>
    <h1>Simple CRUD Application - Employee Management</h1> <hr>
    <div class="login-container"> <h2>Login</h2>
    <?php if (!empty($error)): ?> <div class="message error"><?php echo $error; ?></div>
    <?php endif; ?>
    <form method="POST">
      <div class="form-group"> <label>Username:</label>
        <input type="text" name="username" required autofocus></div>
      <div class="form-group"> <label>Password:</label>
        <input type="password" name="password" required></div>
      <div class="form-group"> <input type="submit" value="Login" style="width: 100%;"></div>
    </form>
    <p style="text-align: center; margin-top: 20px; color: #666;">
      <small>Demo accounts:<br>
        Username: <strong>admin</strong> / Password: <strong>password123</strong><br>
        Username: <strong>user</strong> / Password: <strong>password123</strong>
      </small></p> </div>
  <div class="footer"> @ CT214H - Web Programming </div> </body></html>
```

◆ Create logout.php

```
<?php
session_start();

// Destroy all session data
session_unset();
session_destroy();

// Redirect to login page
header("Location: login.php?message=" . urlencode("You have been logged out successfully"));
exit();
?>
```

Protect CRUD pages:

Add these two lines **at the very top** (line 1, before any HTML/includes that produce output) of every page that requires login:

```
require_once 'data/auth.php';
requireLogin(); // Require login
```

◆ Changing header.php

Change from `<a href="index.php">Login</a>`

TO:

```
<?php if (isLoggedIn()): ?>
    <div class="user-info">
        Welcome, <strong><?php echo htmlspecialchars($_SESSION['username']); ?></strong>
    <?php if (isAdmin()): ?>
        <span style="color: red;">(Admin)</span>
    <?php endif; ?>
    |      <a href="logout.php">Logout</a>
</div>
<?php else: ?>
    <a href="login.php">Login</a>
<?php endif; ?>
    <hr style="clear: both;">
```


◆ Changing index.php

```
<?php
require_once 'data/auth.php';
requireLogin(); // Require login to access this page
include 'templates/header.php';
?>
<?php if (isset($_GET['error'])): ?>
<div class="message error"><?php echo htmlspecialchars($_GET['error']); ?></div>
<?php endif; ?>

<ul>
  <li><a href="create.php">Create</a> - add a new employee</li>
  <li><a href="find.php">Read (Find)</a> - find an employee</li>
  <li><a href="update.php">Update</a> - update employee information</li>
  <?php if (isAdmin()): ?>
  <li><a href="delete.php">Delete</a> - delete employees (Admin only)</li>
  <?php else: ?>
  <li style="color: #999;">Delete - delete employees (Admin only)</li>
  <?php endif; ?>
</ul>

<?php include 'templates/footer.php'; ?>
```